

Guía metodológica para la Encuesta HTMM

1. Propósito de la encuesta

La presente encuesta tiene como propósito medir, con algo de rigor y sin perder el sentido del humor, el grado de adopción y madurez de las organizaciones en materia de modelado de amenazas, con especial atención al enfoque híbrido propuesto por el Hybrid Threat Modeling Method (hTMM) del Software Engineering Institute (SEI) y su posible alineación con el paisaje de amenazas europeo descrito por ENISA. [web:12][web:6][web:13]

Pretende obtener datos comparables entre sectores y países, capturar prácticas reales más allá de las declaraciones de intenciones y proporcionar insumos para construir indicadores de madurez (IGM) y análisis de ROI en modelado de amenazas. [web:12][web:6][web:13][web:7]

2. Marco conceptual

El diseño de la encuesta se apoya en tres pilares conceptuales:

1.

Hybrid Threat Modeling Method (hTMM)

Definido por el SEI como un método que combina SQUARE (para requisitos de seguridad), Security Cards (para fomentar la creatividad), Persona non Grata (PnG, para estructurar atacantes) y STRIDE (para clasificar amenazas). Su objetivo declarado es reducir falsos positivos, minimizar amenazas pasadas por alto, mejorar la consistencia y ofrecer evidencia empírica de su eficacia. [web:12][web:6][web:5]

2.

Paisaje de amenazas europeo (ENISA Threat Landscape 2025)

ENISA analiza casi 4.900 incidentes verificados entre julio de 2024 y junio de 2025, destacando la preeminencia de campañas de DDoS, el incremento de ransomware y la convergencia de actores criminales, estatales y hacktivistas en un ecosistema de amenazas híbridas. [web:13][web:7][web:18]

3.

Integración con marcos de riesgo y resiliencia

Los resultados de hTMM no son un fin en sí mismos, sino un insumo para métodos de análisis de riesgos, decisión de inversiones y planificación de continuidad de negocio. Trabajos recientes sobre marcos híbridos (que combinan STRIDE, ATT&CK y CVSS) demuestran la viabilidad de convertir modelos de amenaza en métricas cuantitativas accionables. [web:8][web:15]

Hybrid Threat Modeling Method (hTMM)

Definido por el SEI como un método que combina SQUARE (para requisitos de seguridad), Security Cards (para fomentar la creatividad), Persona non Grata (PnG, para estructurar atacantes) y STRIDE

(para clasificar amenazas). Su objetivo declarado es reducir falsos positivos, minimizar amenazas pasadas por alto, mejorar la consistencia y ofrecer evidencia empírica de su eficacia. [web:12][web:6][web:5]

Paisaje de amenazas europeo (ENISA Threat Landscape 2025)

ENISA analiza casi 4.900 incidentes verificados entre julio de 2024 y junio de 2025, destacando la preeminencia de campañas de DDoS, el incremento de ransomware y la convergencia de actores criminales, estatales y hacktivistas en un ecosistema de amenazas híbridas. [web:13][web:7][web:18]

Integración con marcos de riesgo y resiliencia

Los resultados de hTMM no son un fin en sí mismos, sino un insumo para métodos de análisis de riesgos, decisión de inversiones y planificación de continuidad de negocio. Trabajos recientes sobre marcos híbridos (que combinan STRIDE, ATT&CK y CVSS) demuestran la viabilidad de convertir modelos de amenaza en métricas cuantitativas accionables. [web:8][web:15]

3. Estructura de la encuesta y lógica de secciones

La encuesta se ha diseñado en nueve bloques, que responden a los ejes principales de madurez identificados en la literatura y en los informes de amenaza:

- Datos generales de la organización: permiten segmentar resultados por sector, tamaño y rol del respondente.
- Madurez general en modelado de amenazas: recoge el grado de formalización, frecuencia y alcance actual del modelado de amenazas, independientemente de hTMM.
- Conocimiento y adopción del hTMM: explora específicamente el nivel de exposición al método híbrido, el uso de sus componentes (Security Cards, PnG, STRIDE) y la percepción de su utilidad.
- Cobertura de amenazas y consistencia: indaga si se miden aspectos como la cobertura por categorías, la consistencia entre equipos y la gestión de falsos positivos.
- Indicadores, métricas y cuadro de mando: aborda el grado de instrumentación mediante KPIs y su enlace con el análisis de riesgo.
- Dimensión territorial y comparativa: analiza la alineación con las tendencias de amenazas en la UE, poniendo foco en España pero sin perder el horizonte internacional.
- Integración con continuidad de negocio y resiliencia: examina la vinculación con parámetros como RTO, RPO y escenarios de continuidad.
- Aspectos organizativos y culturales: explora quién participa, cómo se percibe el modelado de amenazas y qué barreras existen.
- Métricas económicas, IGM y ROI: introduce el componente económico, indispensable para convencer a según qué comités de inversión.

4. Diseño de las preguntas y escalas de respuesta

Se han utilizado mayoritariamente escalas ordinales de 4 niveles (de inexistente a avanzado) o de selección múltiple, con formulaciones en lenguaje llano y, cuando corresponde, una pizca de ironía para mantener despierta a la persona encuestada. [web:12][web:6]

Las razones de diseño son:

- Facilitar el análisis comparativo y el cálculo de un Indicador Global de Madurez (IGM) agregando respuestas por bloques.
- Evitar el exceso de tecnicismos sin renunciar a conceptos clave (Security Cards, PnG, STRIDE, ATT&CK, CVSS).
- Permitir que tanto organizaciones muy maduras como aquellas en fase prehistórica de modelado de amenazas encuentren opciones que reflejen su realidad.

5. Uso previsto de los resultados

Los resultados de la encuesta están pensados para:

- Construir distribuciones de madurez por sector y tamaño, identificando brechas y necesidades específicas.
- Alimentar análisis de correlación entre madurez en modelado de amenazas y exposición a determinados tipos de incidentes (por ejemplo, ransomware o campañas de DDoS) tomando como referencia informes europeos. [web:13][web:7][web:18]
- Servir como base para un diálogo informado entre reguladores, operadores de servicios esenciales y proveedores tecnológicos sobre estándares mínimos de modelado de amenazas.
- Justificar, con datos y sin resortes mágicos, iniciativas de formación, adquisición de herramientas o rediseño de procesos.

6. Recomendaciones para la administración y el análisis

4.

Asegurar representatividad

Se recomienda difundir la encuesta entre diferentes perfiles (CISO, responsables de TI/OT, riesgos, continuidad) para evitar sesgos de perspectiva.

5.

Conservar el anonimato cuando proceda

La franqueza en las respuestas tiende a incrementar cuando no hay riesgo inmediato de inspección fiscal de la conciencia. Se sugiere ofrecer opciones de anonimato o agregación sectorial.

6.

Calcular indicadores por bloque

Cada bloque puede agregarse en un sub-índice (p.ej. madurez de método, integración con riesgo, alineación UE), antes de componer un IGM global.

7.

Contrastar con datos externos

Comparar la autopercepción de madurez con datos de incidentes propios y con informes como ENISA Threat Landscape puede revelar optimismos desmedidos o modestias innecesarias. [web:13] [web:7][web:18]

8.

Repetir la medición periódicamente

Un único corte temporal sirve de foto; la repetición anual permite detectar tendencias y valorar el impacto de iniciativas específicas.

Asegurar representatividad

Se recomienda difundir la encuesta entre diferentes perfiles (CISO, responsables de TI/OT, riesgos, continuidad) para evitar sesgos de perspectiva.

Conservar el anonimato cuando proceda

La franqueza en las respuestas tiende a incrementar cuando no hay riesgo inmediato de inspección fiscal de la conciencia. Se sugiere ofrecer opciones de anonimato o agregación sectorial.

Calcular indicadores por bloque

Cada bloque puede agregarse en un sub-índice (p.ej. madurez de método, integración con riesgo, alineación UE), antes de componer un IGM global.

Contrastar con datos externos

Comparar la autopercepción de madurez con datos de incidentes propios y con informes como ENISA

Threat Landscape puede revelar optimismos desmedidos o modestias innecesarias. [web:13][web:7]
[web:18]

Repetir la medición periódicamente

Un único corte temporal sirve de foto; la repetición anual permite detectar tendencias y valorar el impacto de iniciativas específicas.

7. Notas sobre el tono y la comunicación

El tono deliberadamente ameno y ligeramente irónico de algunas preguntas no es un accidente estilístico, sino una estrategia para contrarrestar el tedio que produce cualquier cuestionario que contenga, en la misma frase, las palabras “madurez”, “indicadores” y “riesgo”.

Se recomienda conservar ese tono en las comunicaciones a las organizaciones, subrayando que el objetivo no es “cazar” incumplimientos, sino comprender el estado real de la práctica y construir, entre todos, algo parecido a una inteligencia colectiva en modelado de amenazas.